



Application Security a Cybersecurity Component

Components of Cybersecurity: Application Security



Application security refers to the developing, adding, and testing security features in applications to prevent security vulnerabilities against threats like unauthorized access and modification

It is crucial because applications are increasingly accessed across many networks and to the cloud, increasing susceptibility to security threats and breaches

Importance of Application Security



Modern applications are more susceptible to security attacks and breaches since they are usually accessible over many networks and are connected to the cloud



Incentives and pressure to ensure security within individual applications and at the network level are growing



Application-level vulnerabilities can be revealed by application security testing. This is ultimately helpful in preventing cyberattacks

What are Application Security Controls?

4



Application security controls strengthen an application's coding-level security, reducing its vulnerability to cyber attackers



Many of these controls deal with how the application responds to unexpected inputs that a cybercriminal might use to exploit a weakness



A programmer can write an application's code to have more control over results of these unforeseen inputs



Application Security Controls: Preventative Controls



01

Preventative measures are taken to stop attacks from taking place and guard against vulnerabilities

02

Access control and encryption are two standard preventative controls used in the software development lifecycle to stop unauthorized users from accessing sensitive data

03

Comprehensive application security testing is another preventative control



Application Security Controls:

Corrective Controls



01



Corrective measures lower the impact of attacks or other incidents

02



Corrective controls include using virtual computers, terminating dangerous or vulnerable applications, or patching software to fix vulnerabilities

Application Security Controls: Detective Controls



Detective controls are essential for a comprehensive application security architecture because these can, sometimes, be the sole means through which security experts determine an attack's occurrence



Detective controls include intrusion detection systems, antivirus scanners, and mechanisms that monitor system health and availability



Types of Application Security

Types of Application Security: Authentication



Types of Application Security: Authentication



Types of Application Security: Encryption



After a user has been approved and is using the application, additional security procedures can prevent cybercriminals from seeing or using sensitive data



Sensitive data is protected by encrypting the traffic between the end-user and cloud in cloud-based apps

Types of Application Security: Logging



Logging can help investigate a security breach in an application; it reveals who had access to the data and how



Application log files record who had accessed what portions of the application and when this happened

Application Security Testing & Tools

01

Application security testing ensures that all security controls are functioning efficiently and effectively

02

Application vulnerabilities and security problems can be found, fixed, and resolved using a comprehensive application security methodology



Application Security Testing & Tools

01

Application security testing ensures that all security controls are functioning efficiently and effectively

02

Application vulnerabilities and security problems can be found, fixed, and resolved using a comprehensive application security methodology



Static Application Security Testing (SAST)



SAST assists in the detection of code vulnerabilities as it looks for the underlying cause in the application source files



The capacity to compare scan results of static analysis with real-time solutions speeds up the discovery of security issues. This lowers Mean Time to Recovery (MTTR) and enables collaborative troubleshooting

Dynamic Application Security Testing (DAST)

16

01

DAST is a more proactive strategy, simulating security breaches on a live web application to provide precise information about exploitable vulnerabilities

02

DAST evaluates applications while they are running in production, making it especially helpful for identifying runtime or environment-related issues



Interactive Application Security Testing (IAST)

01

IAST combines characteristics of SAST and DAST. It conducts an analysis from within the application in real-time or at any point during the development or production process

02

IAST can give more accurate results and offer more thorough access than earlier versions since it has access to all codes and components of the application



Runtime Application Security Protection (RASP)



RASP functions within the application as well, but its main concern is security rather than testing



RASP provides continuous security checks and automatic responses to potential breaches. This may include terminating the session and notifying IT teams



Application Security on Cloud

19

01

Application security on cloud poses enhanced risks. Since cloud environments offer shared resources, special attention must be given to ensure that users have access to the information they are authorized to view in their cloud-based applications

02

Sensitive information is also more prone to security breaches in cloud-based applications as that data is shared across the internet from the user to the application and back



Mobile Application Security



Mobile devices are more vulnerable to attacks since they send and receive data over internet instead of a private network



For employees that login into applications remotely, organizations may use Virtual Private Networks (VPNs) to add a layer of mobile application protection



Before permitting employees to use mobile apps on mobile devices that connect to the corporate network, IT departments may choose to review these and verify that they comply with the company's security requirements



Web Application Security

Web application security is meant for web applications or services that users access through a browser interface on the internet



01

02



The information must be sent to and from the user across the internet since remote servers host web applications

03



Web application security is necessary for businesses hosting or offering online services. These businesses often protect their network from intrusion with a web application firewall



Risk Management

What is Risk Management?



Risk Management Process

Risk management is a process for identifying, assessing, and mitigating vulnerabilities and threats to the essential functions that a business must perform to serve its customers.

➤ Phases of Risk Management

- Identify Mission Essential Functions
- Identify Vulnerabilities
- Identify Threats
- Analyze Business Impacts
- Identify Risk Response



➤ Risk Management Strategies

- Risk Mitigation
- Risk Deterrence
- Risk Avoidance
- Risk Transference
- Risk Acceptance
- Residual Risk
- Risk Appetite



➤ Risk Mitigation

This involves taking steps to reduce the severity or likelihood of a risk. It includes implementing controls or measures to minimize the impact of potential risks.



Risk Deterrence

This strategy focuses on discouraging actions that might lead to risk. It can involve measures that make risky actions less attractive or more difficult to undertake.



Risk Avoidance

This involves altering plans to eliminate a risk or choosing not to engage in activities that are considered too risky. Essentially, it's about not taking the risk at all.



Risk Transference

This strategy involves shifting the risk to another party. Common methods include outsourcing, purchasing insurance, or entering into partnerships.



Transfer Risk

Risk Acceptance

Sometimes, the best strategy is to accept the risk when the cost of mitigating it is greater than the risk itself. This approach involves recognizing the risk and choosing to proceed with the understanding that the potential impact is manageable.



Residual Risk

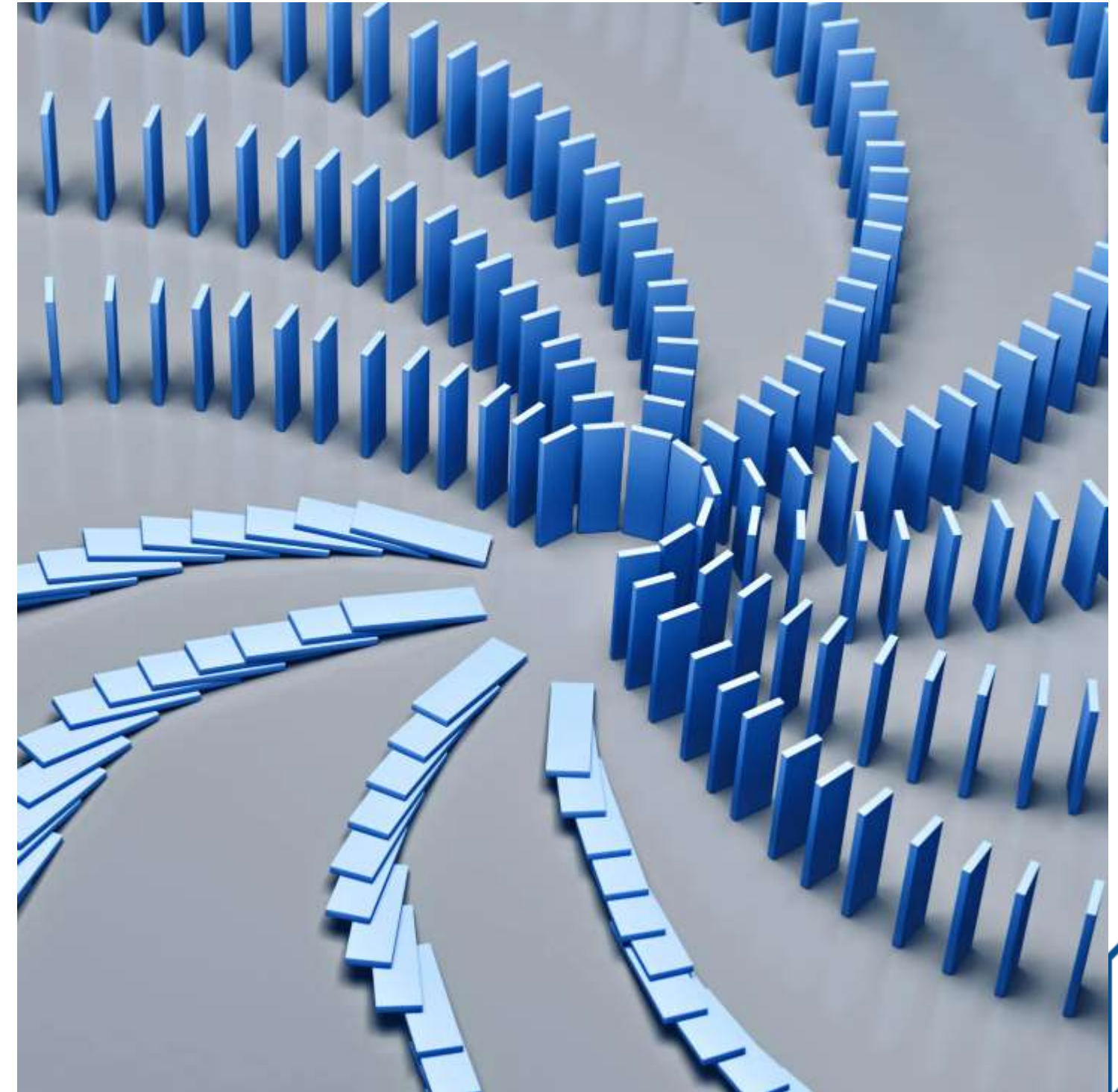
This is the amount of risk that remains after all risk mitigation efforts have been implemented.

It's the risk that is left over after controls have been applied.



Risk Appetite

This is the level of risk an organization is willing to accept in pursuit of its goals. It defines the amount and type of risk that is considered acceptable in order to achieve the organization's objectives.



Data Classification and Compliance

Data Classifications

Data classification and typing schemas tag data assets so that they can be managed through the information lifecycle.

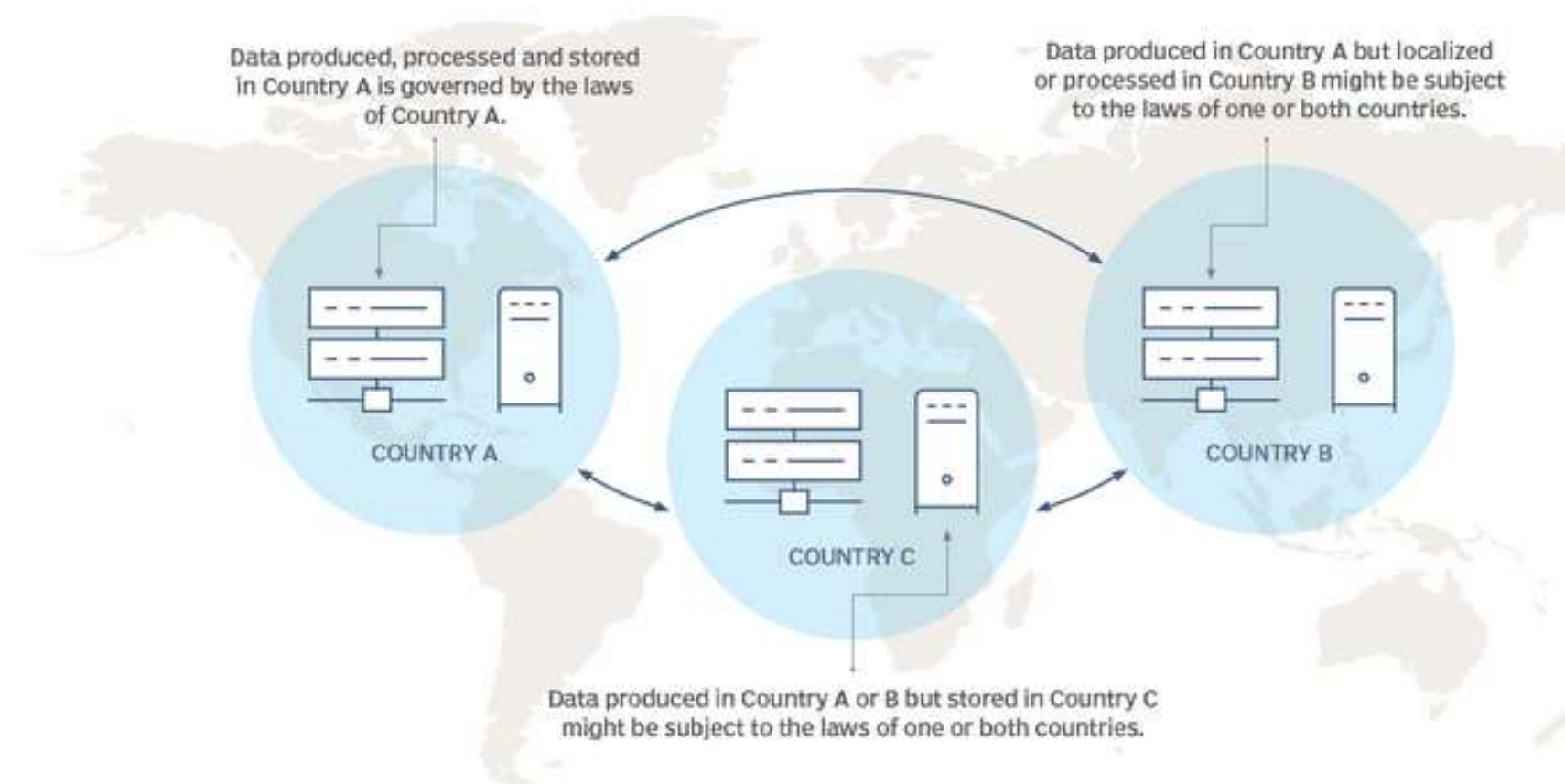
- **Data classification schema**
 - Public
 - Confidential
 - Critical
- **Classification based on kind of information asset**
 - Proprietary
 - Private/Personal Data
 - Sensitive
 - Restricted

Data Sovereignty

Data sovereignty refers to a jurisdiction preventing or restricting processing and storage from taking place on systems that do not physically reside within that jurisdiction.

Data sovereignty scenarios

Data moving across borders might be subject to the laws of the sending and receiving nations.



➤ Geographical Considerations

- Storage locations might have to be carefully selected to mitigate data sovereignty issues.
- Employees needing access from multiple geographic locations.
- **Geographical Restrictions**
 - Geolocation requirements impact data protection practices by requiring organizations to ensure data remains within a designated boundary, such as utilizing local datacenters or cloud providers.
 - Geolocation requirements impact incident investigation and forensics activities because they often include jurisdiction-specific data access and sharing restrictions, and other legal requirements.

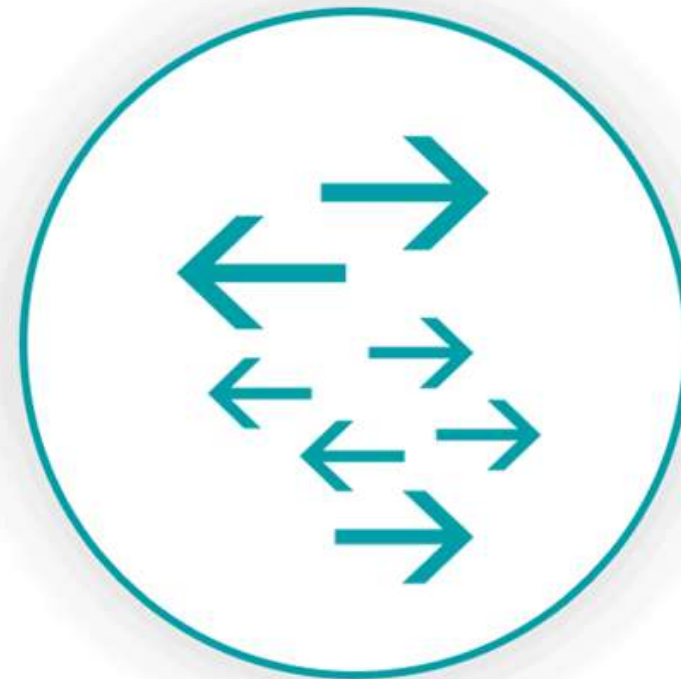
Data Protection

THE THREE STATES OF DATA

AT REST



IN TRANSIT



IN USE



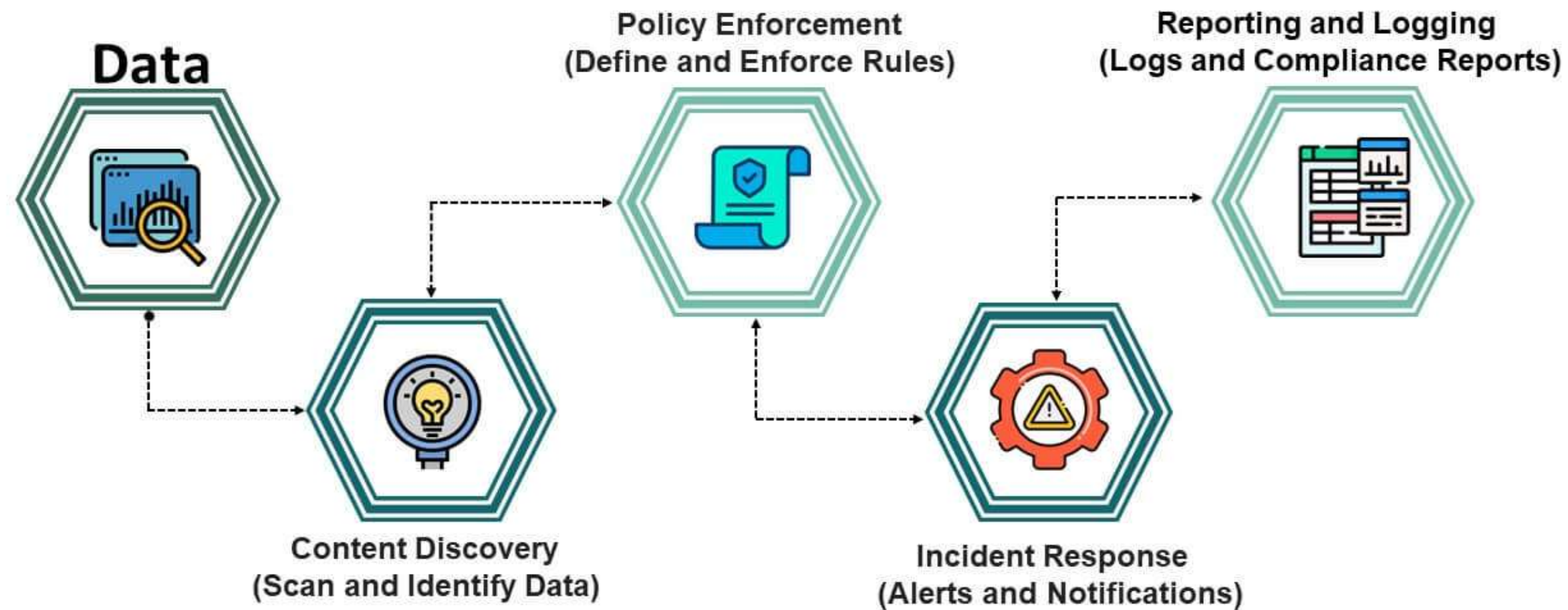
➤ Data Protection

➤ Data protection Methods

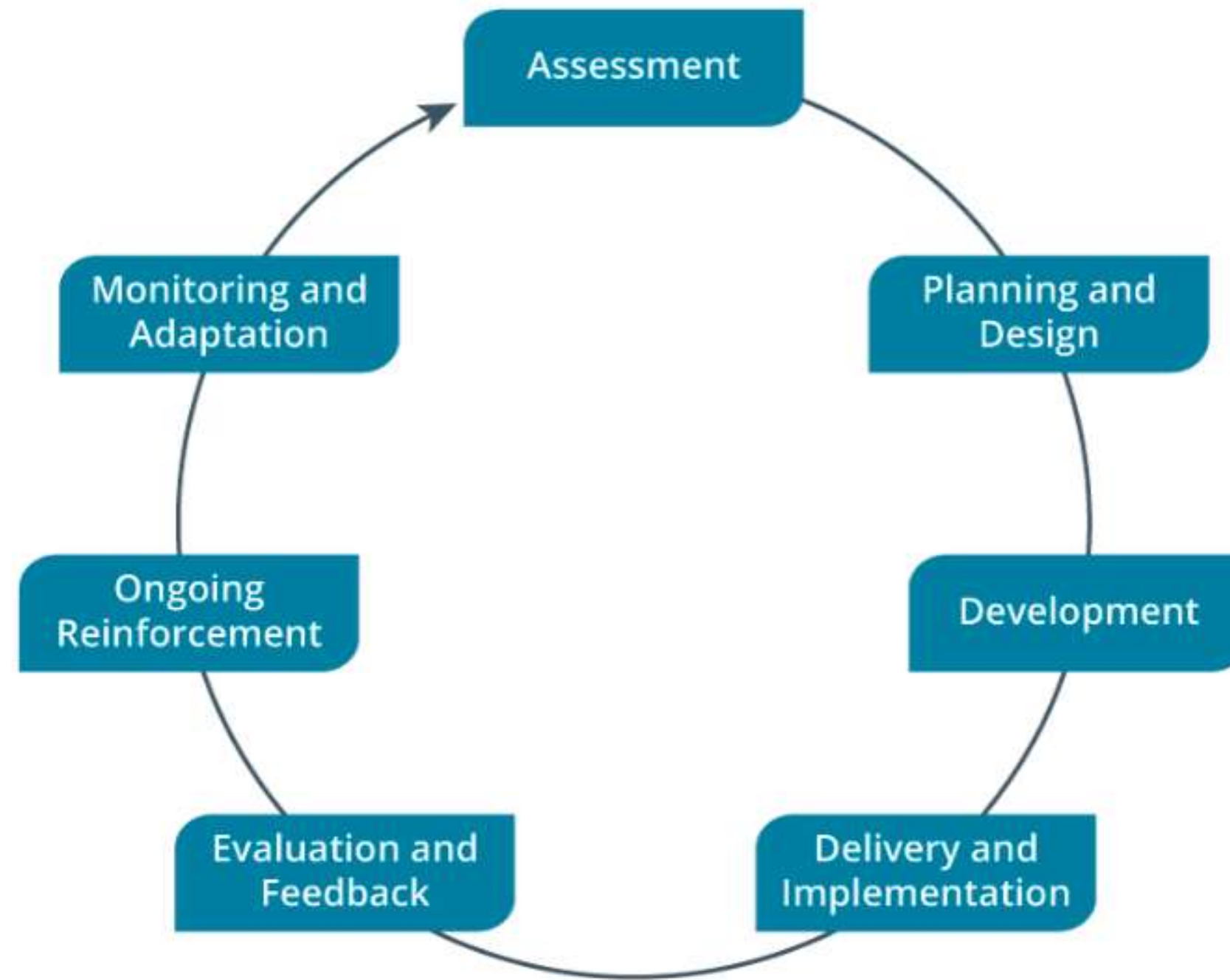
- Geographic Restrictions
- Encryption
- Hashing
- Masking
- Tokenization
- Obfuscation
- Segmentation
- Permission Restrictions

Data Loss Prevention

Data Loss Prevention



Security Awareness Training Lifecycle

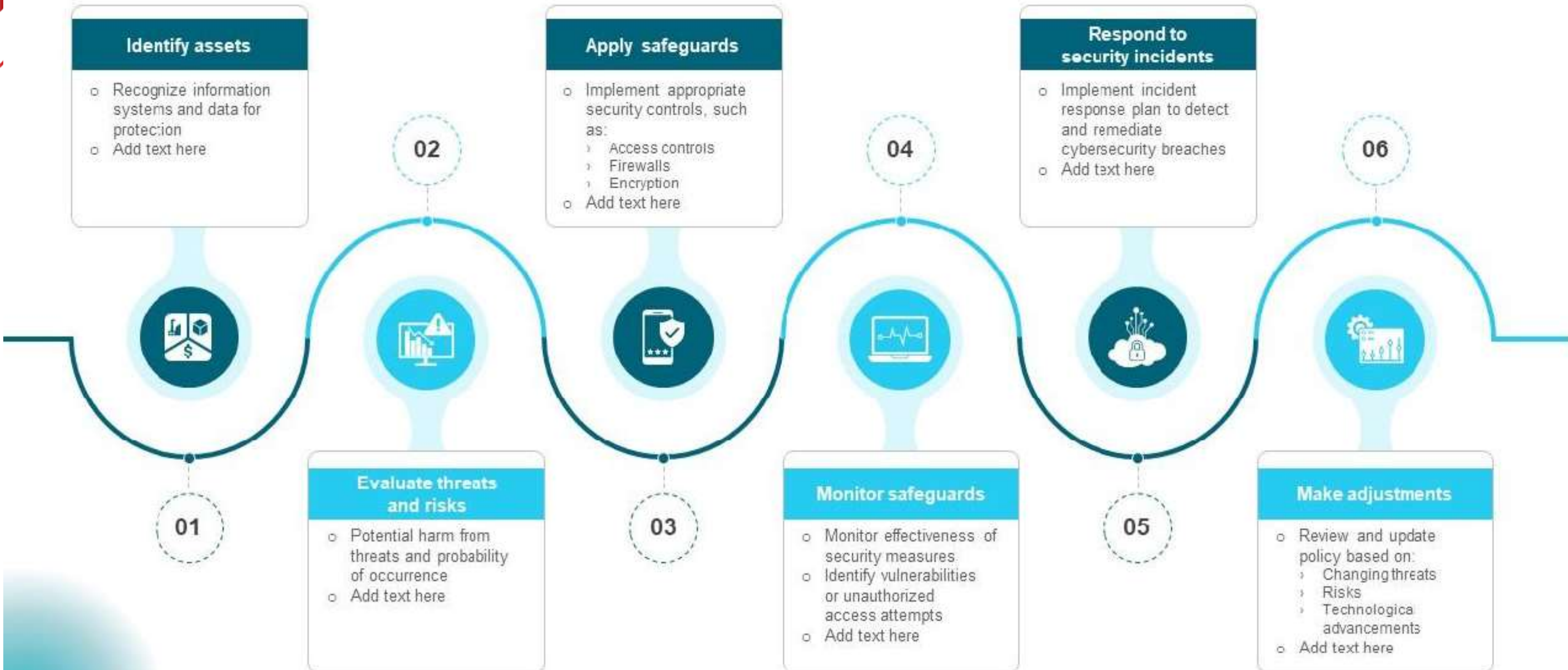




Cyber Security Policy



Steps in Cyber security Policy Cycle



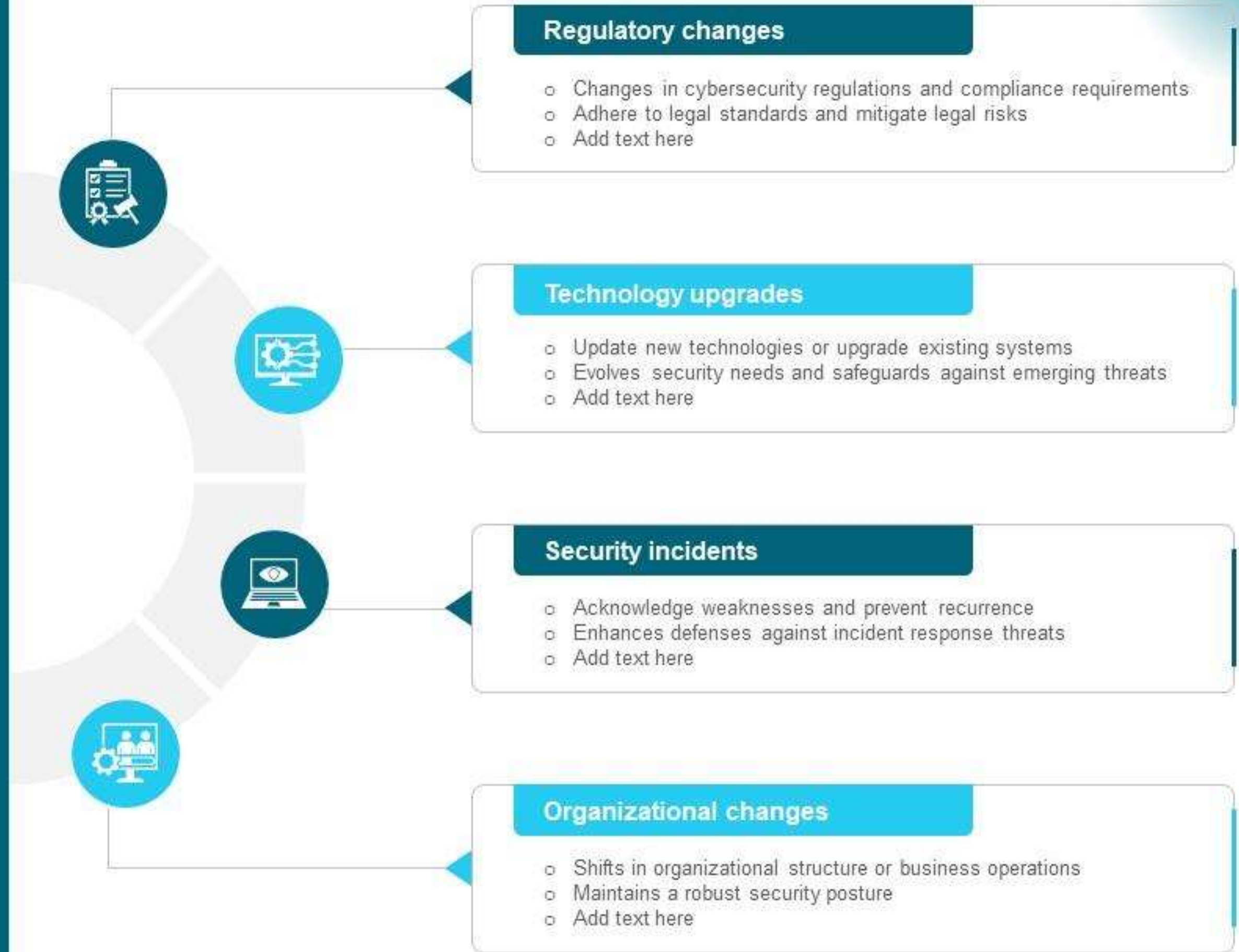
Key aspects of various cyber security policies

This slide covers the key elements of various cybersecurity policies. The purpose of this template is to provide a comprehensive overview of specific cybersecurity policies, including Cloud Policy, Information Policy, Physical Policy, Data Retention Policy, and Access Control Policy.



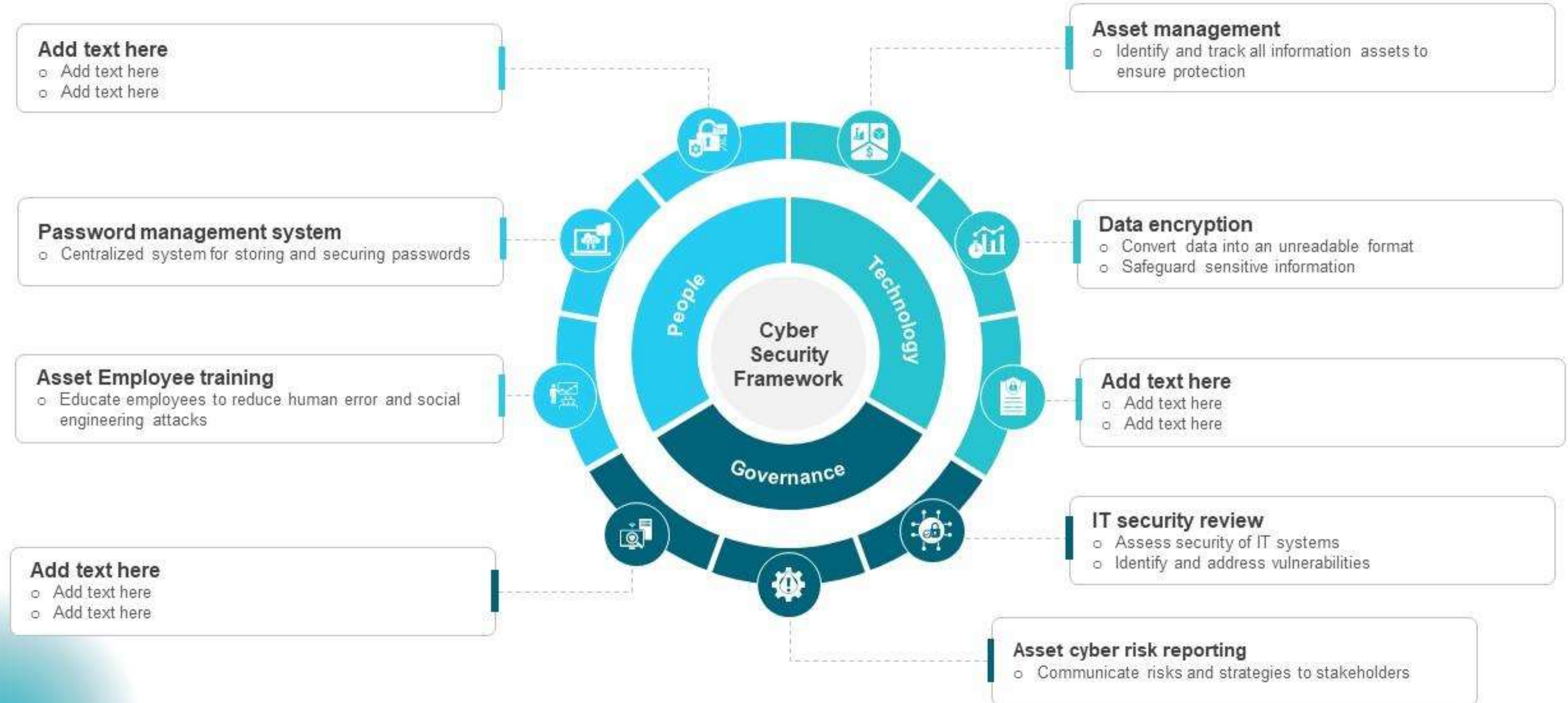
Key factors for updating cyber security policy

This slide covers key reasons for updating cybersecurity policies. The purpose of this template is to serve as a quick reference for stakeholders, outlining the pivotal circumstances that necessitate policy revisions. It includes regulatory changes, technology upgrades, security incidents, and organizational shifts.



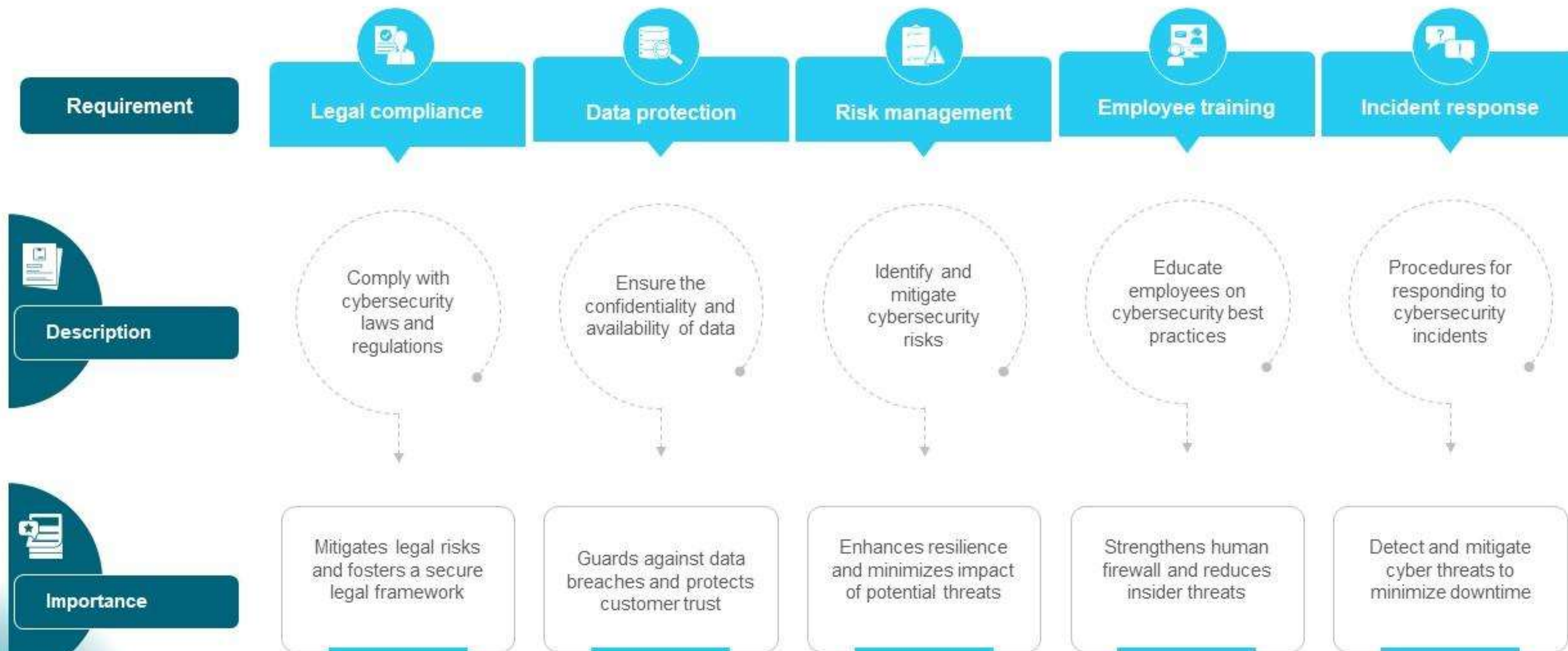
Key phases of cyber security policy framework

This slide covers key components of a robust cybersecurity framework. The purpose of this template is to provide a comprehensive overview of essential cybersecurity components, including Asset Management, Data Encryption, IT Security Review, Cyber Risk Reporting, Employee Training, and Password Management System.



Requirement for effective cyber security policy

This slide covers the imperative reasons for the need of cybersecurity policies. The purpose of this template is to articulate the significance of policies in ensuring legal compliance, data protection, effective risk management, employee training, and incident response.



Cyber security policies for robust organizational network

This slide covers essential cybersecurity policies. The purpose of this template is to provide a focused understanding of the intrusion prevention policy, host integrity policy, live update policy, and information security policy.



Intrusion prevention policy

- Prevent unauthorized access and data breaches
- Key elements
 - › IPS deployment strategies
 - › Incident response procedures



Host integrity policy

- Maintain integrity for unauthorized changes or modifications
- Key elements
 - › Host-based intrusion detection systems (HIDS)
 - › File integrity monitoring (FIM)



Add text here

- Add text here
- Add text here
- Add text here
- Add text here



Information security policy

- Establish framework for protecting confidentiality and integrity
- Key elements
 - › Risk assessment and management
 - › Business continuity planning

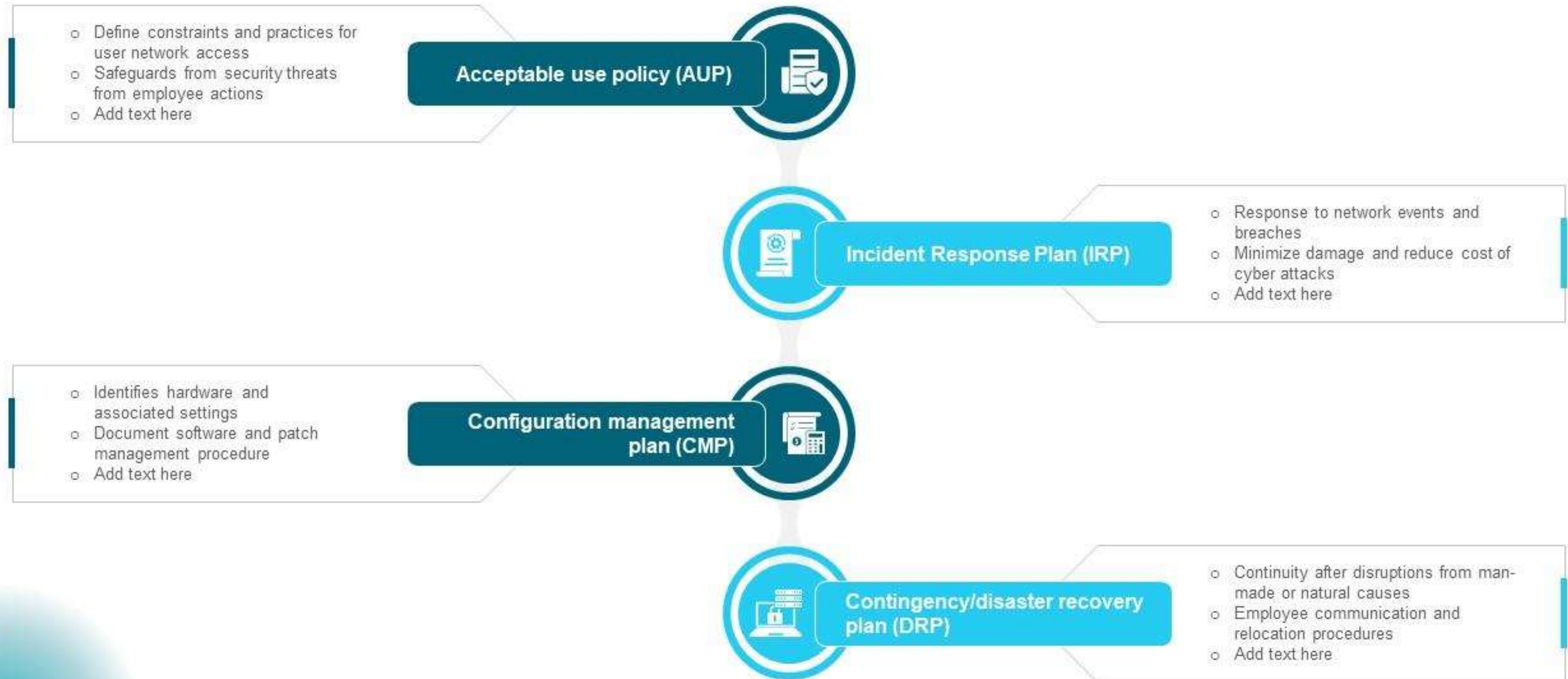


Live update policy

- Ensure consistency in security patches and software fixes
- Key elements
 - › Risk assessment and management
 - › Business continuity planning

Various types of essential cyber security policy plans

This slide covers essential cybersecurity policies for every company. The purpose of this template is to provide a quick reference for stakeholders, detailing the importance of an Acceptable Use Policy (AUP), Incident Response Plan (IRP), Configuration Management Plan (CMP), and Contingency/Disaster Recovery Plan (DRP).



Cyber security policies for employee safety

This slide covers crucial cybersecurity policies designed to ensure employee safety. The purpose of this template is to provide a concise reference for stakeholders. It includes BYOD Policy, Remote Work Policy, E-Commerce Policy, Password Policy, and Email Policy.



BYOD Policy

- Use of personal devices for work for employee flexibility
- Security measures and acceptable use guidelines



E-Commerce Policy

- Secure online transactions and protects sensitive information
- Addresses secure payment processing and customer privacy



Email policy

- Secure and responsible use of email to prevent phishing and unauthorized access
- Encompasses email encryption and guidelines for handling sensitive information



Remote work policy

- Security measures for employees working outside office environment
- Covers secure network access and communication protocols



Password Policy

- Guidelines for creating, managing, and securing passwords
- Specifies password requirements and multi-factor authentication

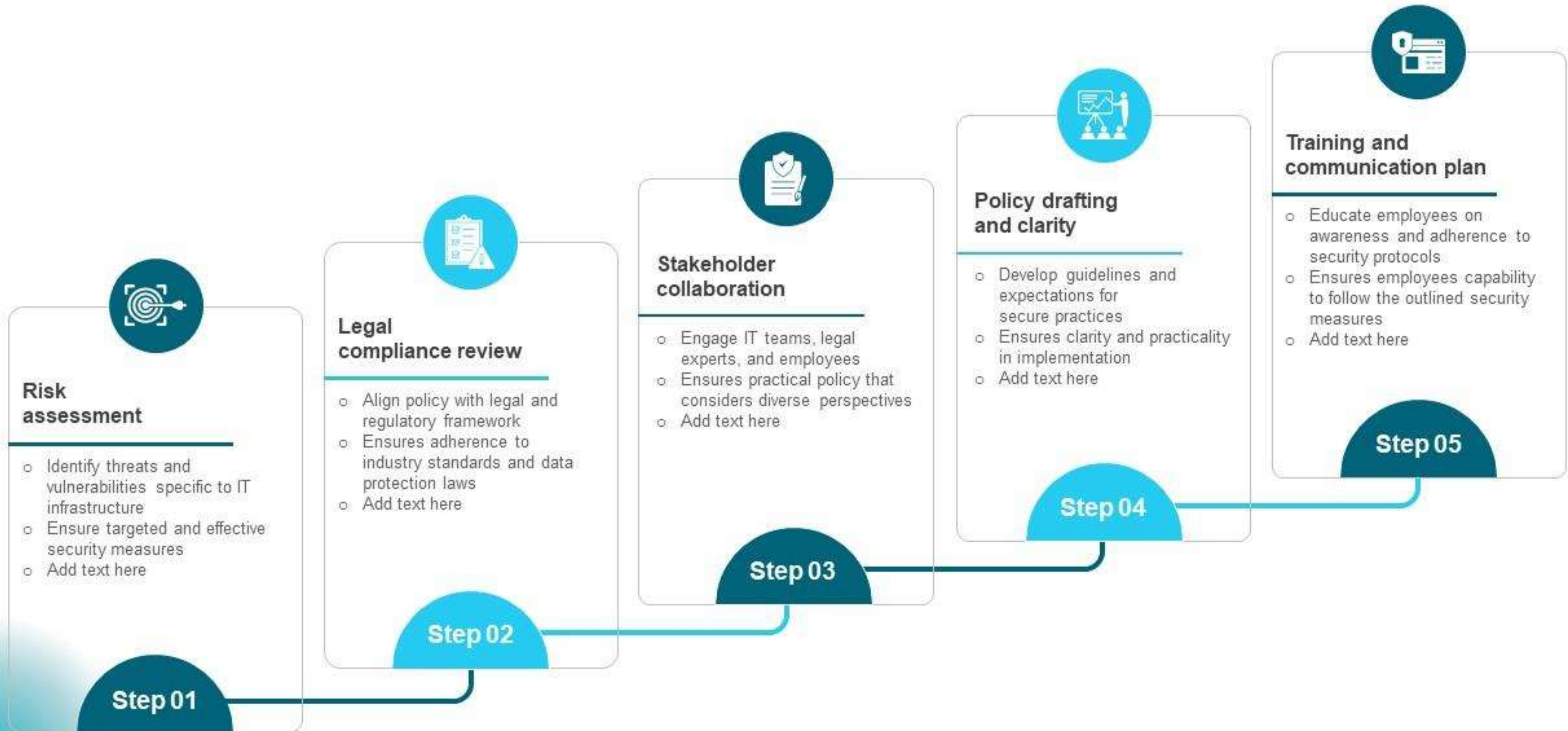


Add text here

- Add text here
- Add text here

Process to create cyber security policy

This slide covers a strategic five-step process for creating a robust cybersecurity policy. The purpose of this template is to guide stakeholders through a comprehensive approach involving risk assessment, legal compliance review, stakeholder collaboration, policy drafting, and the implementation of a training and communication plan.



Policy framework for cyber information security

This slide covers key components of an information security policy. The purpose of this template is to serve as a quick reference guide for each component including purpose, audience, information security objectives, data classification, data operations, and responsibilities of personnel.



Impact of cyber security threats on organisational policy

This slide covers the negative impacts of prevalent cybersecurity threats. This template aims to highlight two key negative impacts of threats, including DNS Attacks, SQL Injection, Malware, Phishing, and Ransomware.



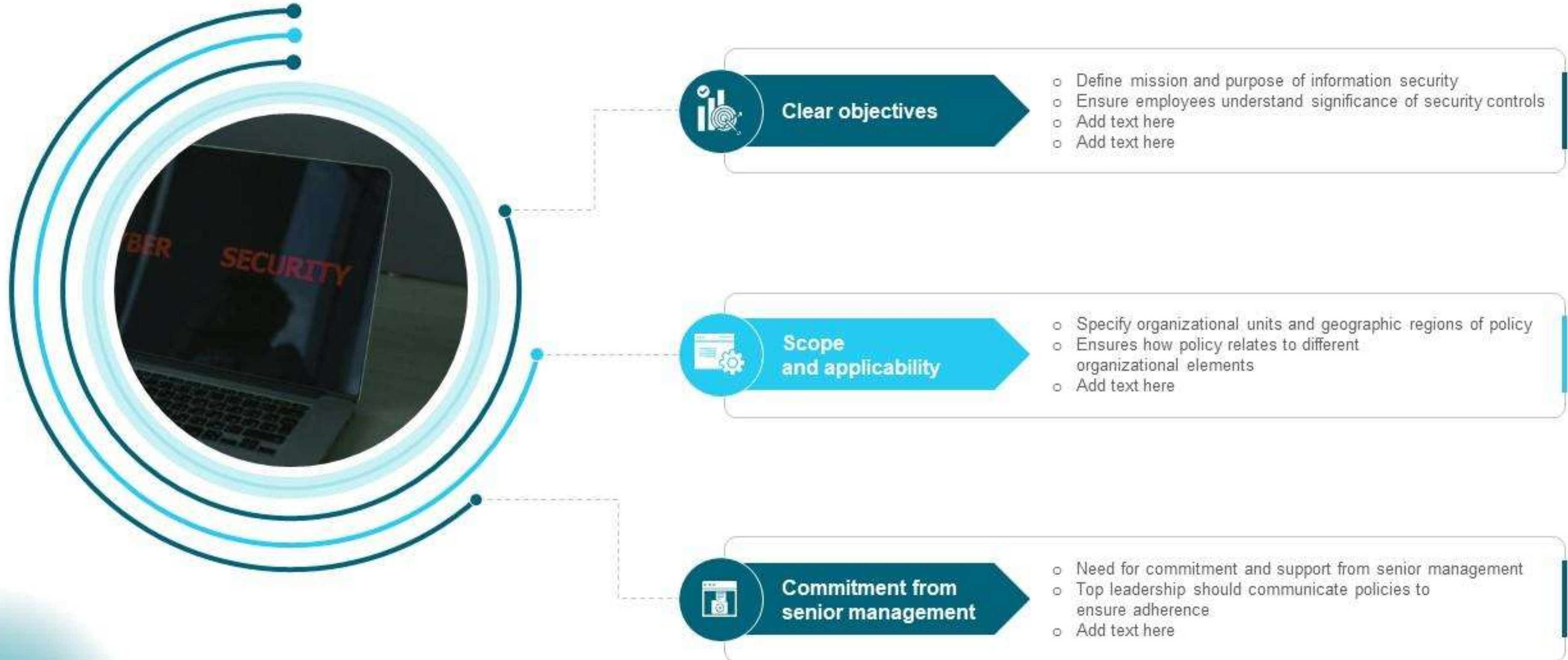
Global cyber security policy components

This slide covers the key components of a National Cyber Security Strategy (NCSS). The purpose of this template is to provide a succinct overview of the main pillars of the NCSS including strengthening the regulatory framework, promoting research and development, etc.



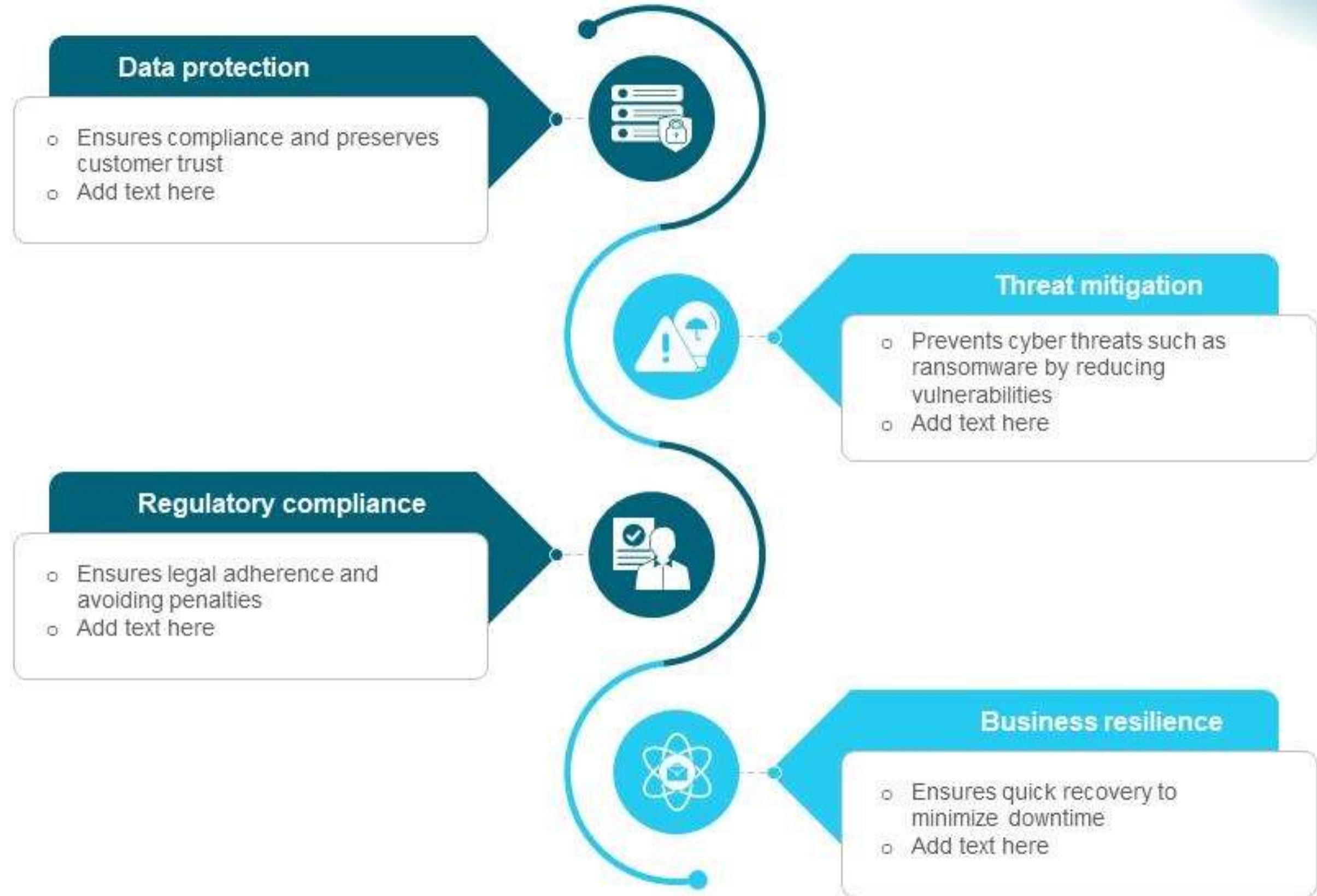
Key elements of cyber security policy

This slide covers the key elements of an effective security policy. The purpose of this template is to provide a concise overview of the essential components, emphasizing the need for a clear purpose and objectives, defining scope and applicability, etc.



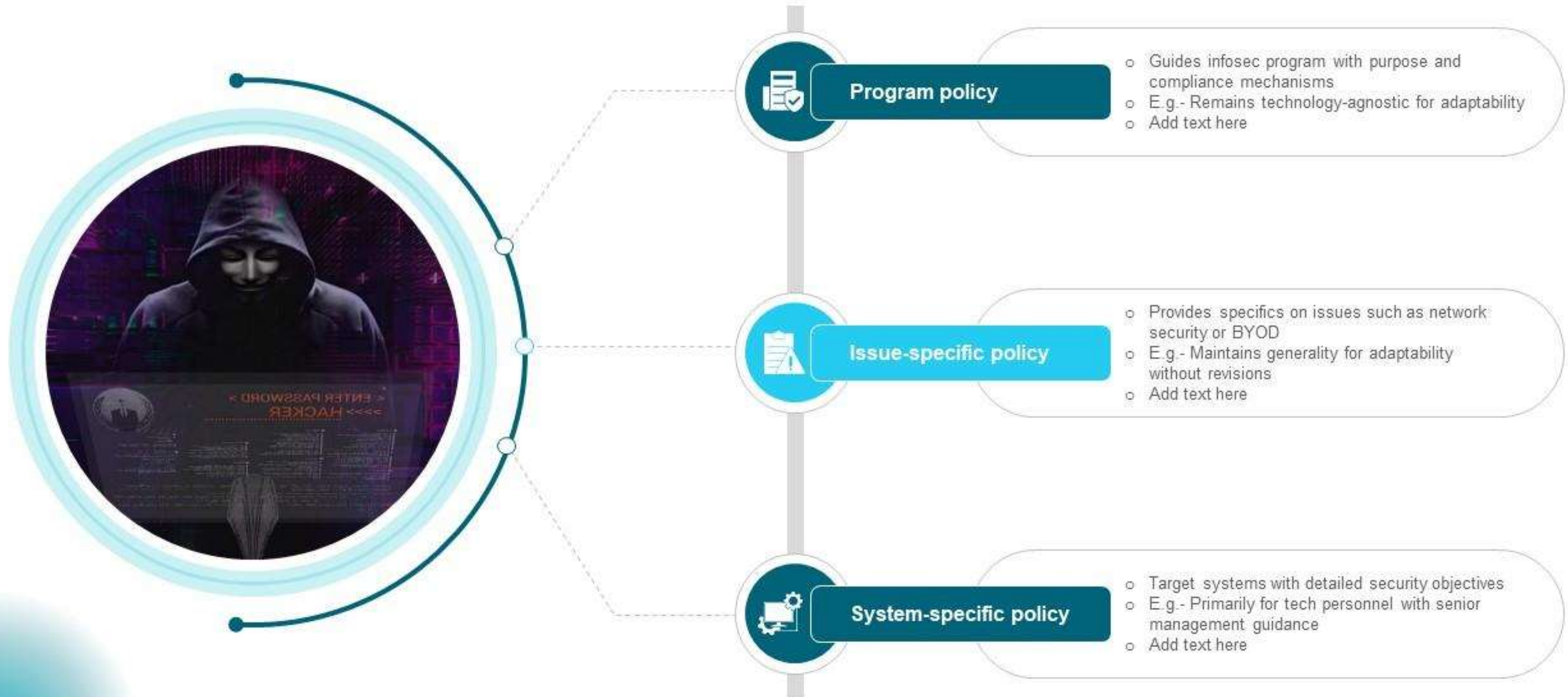
Importance of cyber security policy for IT organisation

This slide covers the essential importance of a cybersecurity policy for IT organizations. The purpose of this template is to emphasize the role of a cybersecurity policy in safeguarding sensitive data, preventing cyber threats, ensuring regulatory adherence, and maintaining uninterrupted business operations.



Cyber security policies safeguarding network Infrastructure

This slide covers essential security policies. The purpose of this template is to provide a comprehensive overview of essential IT security policies, including Program, Issue-Specific, and System-Specific policies.



Cyber security policy icon for data theft prevention

01

Add text here

This slide is 100% editable. Adapt it to your needs and capture your audience's attention.

02

Add text here

This slide is 100% editable. Adapt it to your needs and capture your audience's attention.

03

Add text here

This slide is 100% editable. Adapt it to your needs and capture your audience's attention.



Global cyber security policy icon



01

Add text here

This slide is 100% editable. Adapt it to your needs and capture your audience's attention.

02

Add text here

This slide is 100% editable. Adapt it to your needs and capture your audience's attention.

03

Add text here

This slide is 100% editable. Adapt it to your needs and capture your audience's attention.

Cyber security policy icon for securing digital assets

01

Add text here

This slide is 100% editable. Adapt it to your needs and capture your audience's attention.

02

Add text here

This slide is 100% editable. Adapt it to your needs and capture your audience's attention.

03

Add text here

This slide is 100% editable. Adapt it to your needs and capture your audience's attention.





Thank
you